ROCKET 4 RPO

CHECKLIST JURIDIQUE

Checklist RGPD Recrutement

Les 40 points de conformité pour protéger les données candidats et éviter les sanctions CNIL.

40	24 mois	72h
POINTS DE CONFORMITÉ	CONSERVATION MAX CNIL	DÉLAI NOTIFICATION

40	24 mois	72h
POINTS DE CONFORMITÉ	CONSERVATION MAX CNIL	DÉLAI NOTIFICATION VIOLATION

Le RGPD (Règlement général sur la Protection des Données, UE 2016/679) s'applique à toute collecte de données personnelles de candidats. Les sanctions peuvent atteindre 20 millions d'euros ou 4% du chiffre d'affaires mondial. Cette checklist couvre les obligations essentielles pour un processus de recrutement conforme en France.

Avertissement : Ce document est un guide pratique de conformité. Il ne remplace pas l'avis d'un DPO ou d'un avocat spécialisé en protection des données. Les références d'articles renvoient au RGPD (UE 2016/679) et au Code du travail français.

Base légale du traitement (Art. 6 RGPD)

Quelle base légale pour le recrutement ?
La CNIL recommande l'**intérêt légitime** (Art. 6.1.f) comme base légale principale pour le traitement des candidatures spontanées ou en réponse à une offre. Le consentement (Art. 6.1.a) n'est pas adapté en raison du déséquilibre entre le candidat et le recruteur.

BASE LÉGALE	ARTICLE RGPD	USAGE EN RECRUTEMENT	CONDITION
Intérêt légitime	Art. 6.1.f	Traitement des candidatures	Test de mise en balance obligatoire
Mesures précontractuelles	Art. 6.1.b	Vérification des diplômes, prise de références	À la demande du candidat
Consentement	Art. 6.1.a	Constitution du vivier (conservation post-process)	Libre, spécifique, éclairé, univoque
Obligation légale	Art. 6.1.c	Vérifications réglementaires (casier, habilitations)	Métiers réglementés uniquement

- ☐ La base légale du traitement est identifiée et documentée pour chaque finalité
- ☐ Un test de mise en balance des intérêts a été réalisé (intérêt employeur vs droits candidat) si la base est l'intérêt légitime

- [ ] Le consentement est utilisé uniquement pour le vivier de candidats (conservation au-delà du process de recrutement)
- [ ] Le consentement est recueilli via un formulaire dédié, distinct du formulaire de candidature
- [ ] Le consentement est libre (pas de case pré-cochée), spécifique, éclairé et univoque (Art. 7)

Information des candidats (Art. 13 et 14 RGPD)

L'article 13 impose une information complète du candidat au moment de la collecte directe. L'article 14 s'applique lorsque les données sont obtenues indirectement (sourcing LinkedIn, cooptation).

Mentions obligatoires (Art. 13.1 et 13.2)

#	INFORMATION REQUISE	RÉF. RGPD	CONFORME
1	Identité et coordonnées du responsable de traitement	Art. 13.1.a	
2	Coordonnées du DPO (si désigné)	Art. 13.1.b	
3	Finalités du traitement et base légale	Art. 13.1.c	
4	Intérêts légitimes poursuivis (si Art. 6.1.f)	Art. 13.1.d	
5	Destinataires ou catégories de destinataires	Art. 13.1.e	
6	Transfert hors UE et garanties appropriées	Art. 13.1.f	
7	Durée de conservation ou critères de détermination	Art. 13.2.a	
8	Droits des candidats (accès, rectification, effacement, etc.)	Art. 13.2.b	
9	Droit de retrait du consentement (si applicable)	Art. 13.2.c	
10	Droit de réclamation auprès de la CNIL	Art. 13.2.d	
11	Caractère obligatoire ou facultatif de la fourniture des données	Art. 13.2.e	
12	Existence d'une décision automatisée ou profilage	Art. 13.2.f	

- [ ] Une politique de confidentialité candidat est rédigée et accessible sur le site carrière
- [ ] L'information est fournie au moment de la collecte (formulaire, offre d'emploi)
- [ ] En cas de sourcing (LinkedIn, GitHub), le candidat est informé dans le premier message (Art. 14.3 : délai max 1 mois)

- [ ] Les mentions légales sont présentées sur chaque formulaire de candidature

Données collectées — Principe de minimisation (Art. 5.1.c)

Seules les données adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées doivent être collectées.

DONNÉE	COLLECTE AUTORISÉE	CONDITION
Données d'identification		
Nom, prénom	Oui	Nécessaire
Email, téléphone	Oui	Contact candidat
Adresse postale	Oui (si pertinent)	Mobilité / zone géographique
Photo	Déconseillé	Non pertinent sauf métiers de représentation
Données professionnelles		
CV, lettre de motivation	Oui	Évaluation des compétences
Expérience professionnelle	Oui	En lien avec le poste
Formation, diplômes	Oui	Si requis pour le poste
Prétentions salariales	Oui	Adéquation budget
Disponibilité, préavis	Oui	Planification embauche
Permis de conduire	Oui si justifié	Poste nécessitant un véhicule
Données interdites (Art. 9 — Données sensibles)		
Numéro de sécurité sociale	INTERDIT	Uniquement après embauche
Situation familiale, grossesse	INTERDIT	Art. L1132-1 Code du travail
Religion, opinions politiques	INTERDIT	Art. 9.1 RGPD
Origine ethnique	INTERDIT	Art. 9.1 RGPD
État de santé	INTERDIT	Compétence médecin du travail
Appartenance syndicale	INTERDIT	Art. 9.1 RGPD
Casier judiciaire	INTERDIT (sauf exception)	Métiers réglementés uniquement

- [ ] Les formulaires de candidature ne contiennent pas de champs non pertinents (âge, situation familiale, nationalité)

- [ ] Les notes d'entretien ne contiennent aucun commentaire discriminatoire ou donnée sensible
- [ ] Un audit annuel des champs collectés est réalisé

Durée de conservation (Art. 5.1.e et Art. 17)

Recommandation CNIL : Les données des candidats non retenus doivent être supprimées au plus tard **24 mois** après le dernier contact, sauf consentement explicite pour une durée plus longue (délibération CNIL n°2002-17).

SITUATION	DURÉE MAXIMALE	BASE LÉGALE	ACTION REQUISE
Candidature en cours de process	Durée du recrutement	Intérêt légitime	Suppression à la clôture du poste
Candidat non retenu	24 mois max	Intérêt légitime	Suppression automatique ou manuelle
Vivier avec consentement	24 mois renouvelables	Consentement (Art. 6.1.a)	Renouvellement explicite avant expiration
Candidat embauché	Durée du contrat + 5 ans	Obligation légale	Transfert vers dossier RH
Données de recrutement archivées	5 ans	Art. 2224 Code civil	Archivage intermédiaire sécurisé

- [ ] Une politique de purge automatique est paramétrée dans l'ATS (suppression à 24 mois)
- [ ] Les candidats sont informés de la durée de conservation dans la politique de confidentialité
- [ ] Un process de renouvellement du consentement est en place pour le vivier (email de reconfirmation)
- [ ] Les CV imprimés sont détruits par broyage après numérisation (Art. 5.1.f)
- [ ] Un registre de suppression est tenu (date, volume, méthode)

Droits des candidats (Art. 15 à 22)

DROIT	ARTICLE	DÉLAI DE RÉPONSE	MODALITÉ

Droit d'accès	Art. 15	1 mois	Copie des données en format lisible
Droit de rectification	Art. 16	1 mois	Correction des données inexactes
Droit à l'effacement	Art. 17	1 mois	Suppression si plus de base légale
Droit à la limitation	Art. 18	1 mois	Gel du traitement en cas de contestation
Droit à la portabilité	Art. 20	1 mois	Export en format structuré (CSV, JSON)
Droit d'opposition	Art. 21	1 mois	Opposition au traitement (intérêt légitime)
Décision individuelle automatisée	Art. 22	1 mois	Droit à une intervention humaine

- ☐ Un processus interne est en place pour traiter les demandes dans le délai légal (1 mois, prolongeable de 2 mois si complexe)
- ☐ Les coordonnées pour exercer les droits sont publiées dans la politique de confidentialité
- ☐ Un registre des demandes d'exercice de droits est tenu
- ☐ L'identité du demandeur est vérifiée avant communication des données

Sécurité des données (Art. 32)

Le responsable de traitement et le sous-traitant doivent mettre en oeuvre les mesures techniques et organisationnelles appropriées pour garantir un niveau de sécurité adapté au risque.

- ☐ Les CV et données candidats sont stockés dans un système sécurisé (ATS, espace chiffré)
- ☐ L'accès aux données est limité aux personnes habilitées (recruteurs, hiring managers du poste concerné)
- ☐ L'authentification forte est activée sur l'ATS (MFA / 2FA)
- ☐ Les mots de passe respectent les recommandations CNIL 2022 (12 caractères min, complexité)
- ☐ Les échanges de CV par email sont limités — le partage via ATS est privilégié
- ☐ Aucun CV n'est stocké sur des espaces partagés non sécurisés (Google Drive public, Slack, WhatsApp)
- ☐ Les postes de travail accédant aux données candidats disposent d'un antivirus à jour et d'un chiffrement disque

- [ ] Un registre des violations de données est tenu (Art. 33 : notification CNIL sous 72h en cas de violation)

Sous-traitants et transferts (Art. 28 et Art. 44-49)

Contrats sous-traitants (Art. 28)

Tout sous-traitant qui traite des données candidats pour votre compte doit être encadré par un contrat incluant les clauses de l'Art. 28.3.

- [ ] Un registre des sous-traitants traitant des données candidats est à jour
- [ ] Des clauses RGPD (Art. 28.3) sont incluses dans les contrats avec :

SOUS-TRAITANT	DONNÉES TRAITÉES	CLAUSE ART. 28	TRANSFERT HORS UE
ATS / logiciel de recrutement	CV, identité, historique candidature		
Cabinets de recrutement / RPO	CV, notes d'entretien, évaluations		
Plateformes de tests / assessments	Résultats, identité		
Outils de visioconférence	Enregistrements (si applicable)		
Outils d'emailing / CRM candidat	Email, prénom, historique échanges		
Outils d'IA (ChatGPT, Claude, etc.)	Données saisies dans les prompts		

- [ ] En cas de transfert hors UE : clauses contractuelles types (CCT) ou décision d'adéquation (Art. 45)
- [ ] Les sous-traitants américains sont encadrés par le EU-US Data Privacy Framework ou des CCT (Art. 46)
- [ ] Aucune donnée candidat n'est copiée dans un outil d'IA sans anonymisation préalable

IA et recrutement (AI Act + RGPD)

AI Act européen (Règlement UE 2024/1689) : Les systèmes d'IA utilisés dans le recrutement sont classés **« haut risque »** (Annexe III, point 4). Ils sont soumis à des obligations renforcées : évaluation de conformité, gestion des risques, transparence, supervision humaine et documentation technique.

- [ ] Les outils d'IA utilisés dans le recrutement sont documentés (registre des traitements + registre AI Act)
- [ ] Une analyse d'impact (AIPD / DPIA, Art. 35) est réalisée si traitement automatisé à grande échelle
- [ ] Les candidats sont informés de l'utilisation d'outils automatisés (Art. 13.2.f et Art. 22)
- [ ] Une intervention humaine est garantie dans la décision finale de recrutement (Art. 22.3)
- [ ] Les biais algorithmiques sont audités au moins une fois par an
- [ ] Les données candidats ne sont pas utilisées pour entraîner des modèles d'IA sans consentement

Registre des traitements (Art. 30)

Toute entreprise de 250+ salariés ou tout responsable de traitement dont le traitement est susceptible de comporter un risque pour les droits et libertés des personnes doit tenir un registre.

ÉLÉMENT DU REGISTRE	EXEMPLE RECRUTEMENT
Finalité du traitement	Gestion des candidatures et recrutement de collaborateurs
Catégories de personnes	Candidats (externes et internes)
Catégories de données	Identité, CV, notes d'entretien, évaluations, références
Destinataires	Équipe recrutement, hiring managers, sous-traitants (ATS, outils)
Durée de conservation	24 mois après dernier contact (candidats non retenus)
Mesures de sécurité	Chiffrement, contrôle d'accès, MFA, pseudonymisation
Transferts hors UE	Oui/Non — si oui, garanties (CCT, adéquation, EU-US DPF)

- [ ] Le traitement « recrutement » est inscrit au registre des traitements
- [ ] Le registre est mis à jour au moins une fois par an ou à chaque changement d'outil
- [ ] Le registre est accessible au DPO et à la CNIL en cas de contrôle

Modèle de formulaire de consentement (vivier)

Modèle de clause consentement vivier :

« J'autorise [Nom de l'entreprise] à conserver mes données personnelles (CV, coordonnées, notes d'entretien) dans son vivier de candidats pour une durée de 24 mois à compter de ce jour, dans le but d'être recontacté(e) pour des opportunités correspondant à mon profil. Je comprends que je peux retirer ce consentement à tout moment en écrivant à [email DPO/recrutement]. Ce retrait n'affectera pas la licéité du traitement effectué avant le retrait. »

Signature : _____ **Date :** __ / __ / ____

Checklist DPO — 10 points de contrôle annuel

- ☐ Le registre des traitements « recrutement » est à jour (Art. 30)
- ☐ Les politiques de confidentialité candidat sont publiées et accessibles
- ☐ Les durées de conservation sont respectées — purge effectuée
- ☐ Les contrats sous-traitants incluent les clauses Art. 28
- ☐ Les outils d'IA sont documentés (AI Act) et les candidats informés
- ☐ Les demandes d'exercice de droits ont été traitées dans les délais (registre à jour)
- ☐ Les mesures de sécurité sont adéquates (audit annuel)
- ☐ Les formulaires de candidature ont été audités (minimisation des données)
- ☐ Les hiring managers sont formés aux bonnes pratiques RGPD (au moins 1x/an)
- ☐ Aucune violation de données non signalée n'est identifiée

Synthèse : les 10 réflexes RGPD du recruteur

1. **Informer** le candidat dès la collecte (Art. 13)
2. **Minimiser** : ne collecter que les données nécessaires (Art. 5.1.c)
3. **Supprimer** les données après 24 mois (recommandation CNIL)
4. **Sécuriser** le stockage des CV (Art. 32)
5. **Limiter** l'accès aux personnes habilitées
6. **Consentir** : obtenir un consentement explicite pour le vivier (Art. 6.1.a)
7. **Répondre** aux demandes d'accès sous 1 mois (Art. 12.3)
8. **Encadrer** les sous-traitants par contrat (Art. 28)

9. **Documenter** l'utilisation d'outils d'IA (AI Act)
10. **Former** les hiring managers aux bonnes pratiques RGPD

---

rocket4rpo.com — Tous droits réservés 2026

Données issues de 200+ recrutements réalisés